

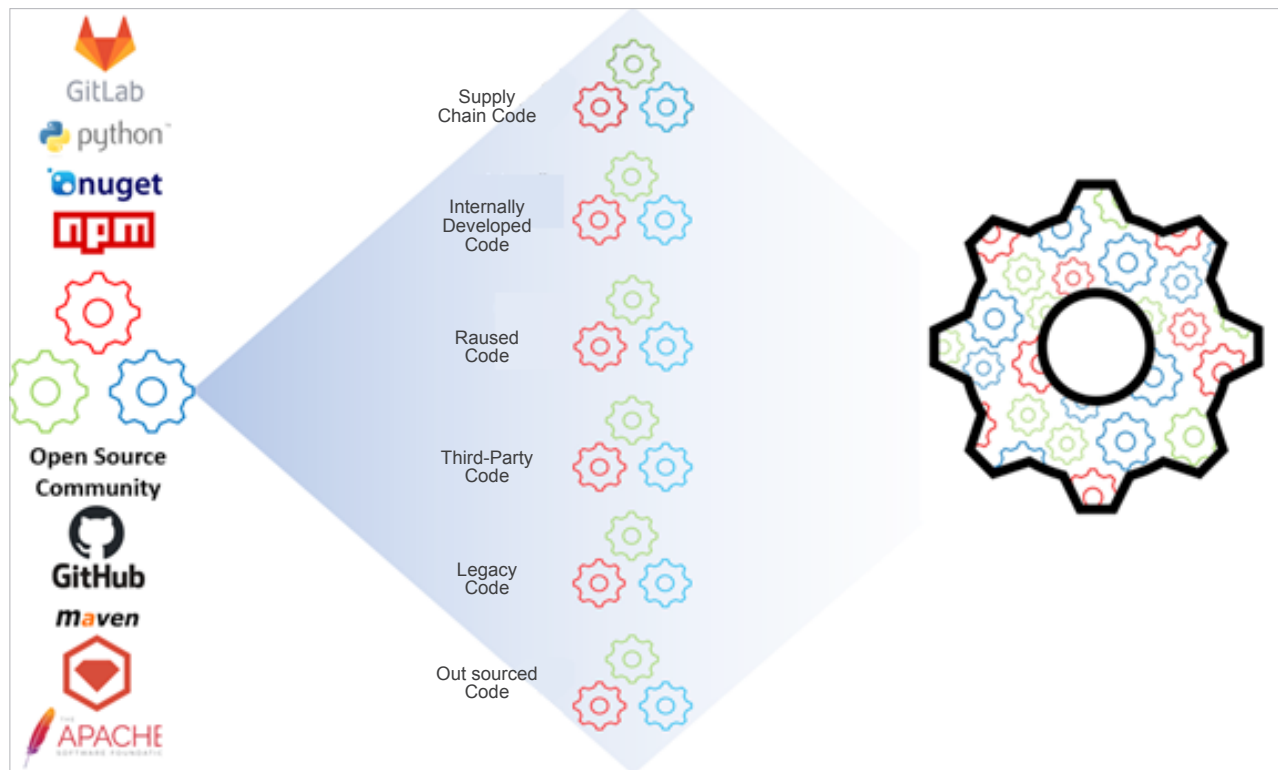


Figure 1: Various entry points of open source components into the supply chain

the developing team to incorporate this software into its code.

Another important aspect with regard to open source compliance risks is the software dependencies. Dependencies are components and libraries that are required for the application to run, and are pulled into the application at build time.

These are categorised into two types — direct dependencies and transitive dependencies. Direct dependencies are the libraries your code directly calls and utilises. Transitive dependencies are the libraries or other software that the direct dependencies depend on.

These dependencies have their own governing licence, which could be different from the parent open source library. It is important to track the dependencies in your software because you are still obligated to comply with the terms of the licence, even if the dependency is direct or transitive.

Open source licence risks and compliance

Each open source software library is governed by an open source licence. These licences can be categorised into different risk levels: permissive, weak copyleft, strong copyleft, and source available, which in turn have obligations, attributions and varying severity of risks associated with them. Figure 2 shows the different licence types and their associated obligations.

Open source software licences obligate the developer or organisation developing software to comply with the terms of the licence. Some of the obligations include keeping the licence information and copyright notices intact, providing attribution notices that identify the copyright holder, identifying modifications made to the software, etc, and in some cases to make the source code of the overall application available to users of the application. Non-compliance with the licence obligations can impact the business in many ways.

- **Licence infringement consequences:** Development teams could lose the right to use the component or library, which could result in a product recall, fixing or re-writing the code patch.
- **Loss of intellectual property (IP):** Open source licence compliance can result in a requirement to release the source code of your IP to users of the application.
- **Reputation loss:** Press articles and media coverage can jeopardise a company's reputation.
- **Cost consequences:** Remediation processes like removing or replacing an open source component can often be expensive and time-consuming.

The reality of licence violations

Non-compliance with open source software in the past has given rise to many disputes, which have made quite an impact on an organisation's reputation and client base.